Sample audit report - one engine path

Client: anonymised. A public Go futures-backtesting engine, 254 stars.
Scope: fee and funding accounting in one path (backtest service).
Turnaround: 48 h from repo access. Fee: USD 29 / CNY 199. No reproducible finding, no fee.
This page is the deliverable format, filled with a real audit we ran. Names removed.

METHOD

Read the engine path end to end (order sizing, fill, funding, metrics). For each suspected defect: write a minimal reproduction, run it, and record the number before and after a fix. Nothing is reported that we could not re-run ourselves. Severity is ranked by how much the headline number moves, not by how interesting the bug is.

FINDINGS (RANKED)

Finding	Severity	Effect on headline	Evidence
F1 funding at exit skipped	high	up to 0.25% equity/event	engine.go, 1 branch
F2 Sortino denominator	medium	Sortino low ~37% (40% neg)	metrics.go, 1 function
F3 nothing else	-	-	rest of path clean

READING

F1: when a position is closed on the bar that carries a funding timestamp, the funding charge for (previous close, this close] is never applied - the position is already nil when the funding walk runs, but the funding index still advances. At 25x leverage a 0.01% funding rate is 0.25% of equity, so a strategy that closes often is quietly flattered. F2: downside deviation divides by the count of negative returns instead of by all observations, so the ratio is not the Sortino anyone quotes; at 40% negative observations the denominator is inflated by sqrt(N/K) = 1.58, i.e. the reported ratio sits about 37% too low. F3 matters as much as F1: we name what we did not find, so the report does not read as a list of grievances.

REPRODUCE

```
git clone <repo> && cd service/backtest && go test ./... # F1: one bar, one funding timestamp at the close, one exit on that bar python3 -m auditkit.cli trades.csv --trials 1 # F2: reported vs recomputed Sortino, side by side Both snippets ship with the report and run without edits.
```

SCOPE AND LIMITS

Files read: 4 of 4 in the backtest path (100% of that path's SLOC). Not read: exchange connectors, API layer.
F1 is a logic defect, proven by execution. F2 is a definition mismatch: we say which definition we used and which one the code uses.
We did not evaluate whether the strategy is profitable, and we did not touch keys, funds or accounts.
No finding, no fee. If the only findings are cosmetic, the fee is zero and we say so in writing.

rytjy - gbbggjvf@gmail.com - github.com/rytjy/backtest-audit-kit